

QA Audit Report

Subic Bay Home Services

Branch: UXRefinements | Method: Live server + browser automation + static code review
Date: June 02, 2026 | Auditor: Claude Code

Scope and Method

This report combines a static code review of all backend routes, controllers, and frontend components with a live server audit. Both servers were run locally (backend port 3000, frontend port 3001) with seeded data. Every major flow was exercised through a real browser session. Security exploits were executed live with curl against the running API. Mobile layout was tested at 375x812 viewport.

Accounts tested	alice@example.com (client), carol@example.com (provider), admin@example.com (admin)
Seed credentials	password123 / admin1234
API base	http://localhost:3000
Frontend	http://localhost:3001
Console errors	ZERO JavaScript errors across all pages (React Router v6 future flag warnings only)

Security Findings

SF-1 Provider API has zero authentication — exploit confirmed live

Severity: CRITICAL

Routes affected	ALL 7 routes in providerRoutes.js — no requireAuth middleware on any
Root cause	getUserId() reads req.userId (never set without middleware) then falls back to req.headers['x-user-id'], a header any attacker can forge
Tested with	curl with no JWT token, only a spoofed x-user-id header

- Read Carol's services with no token — 200 OK
- Create service on Carol's account with no token — 201 Created
- Delete Carol's service with no token — 200 OK
- Overwrite Carol's display name, bio, and availability with no token — 200 OK

Fix: Add `router.use(requireAuth)` at the top of `providerRoutes.js`. One line. Then remove the `x-user-id` header fallback from all provider controllers.

Launch blocker: YES

SF-2 JWT secret has a publicly known hardcoded fallback

Severity: CRITICAL

Location	middleware/auth.js line 3 and authController.js line 12
Fallback	"your-secret-key-change-in-production" (literal string)
Impact	Any attacker can forge admin-role JWTs and impersonate any user if <code>JWT_SECRET</code> env var is not set in production

Fix: Remove the `||` fallback entirely. Throw a startup error if `JWT_SECRET` is not set.

Launch blocker: YES

SF-3 No rate limiting on any endpoint

Severity: HIGH

Affected	POST <code>/api/auth/login</code> , POST <code>/api/auth/register</code> , POST <code>/api/bookings</code> , POST <code>/contact</code>
Confirmed	All endpoints accept unlimited rapid requests — no lockout, no throttle
Risk	Login brute force, registration spam, booking spam, contact form abuse by anyone

Fix: Add `express-rate-limit` middleware to all auth and public-facing endpoints before launch.

Launch blocker: YES

SF-4 `/forgot-password` renders a completely blank white page

Severity: HIGH

Confirmed live	Navigated to <code>/forgot-password</code> — <code>document.body.innerText ===</code> empty string
The link	Prominently shown on the login page as 'Forgot your password?' — first thing a user who forgets their password will click
Root cause	No route exists for <code>/forgot-password</code> in <code>App.js</code>

Fix: Remove the link or implement a password reset route. Do not ship a dead link.

Launch blocker: YES

SF-5 Profile and password routes missing `requireAuth` middleware

Severity: MEDIUM

Routes	GET <code>/api/auth/profile</code> , PATCH <code>/api/auth/profile</code> , POST <code>/api/auth/password/verify</code> , PATCH <code>/api/auth/password</code>
Current state	Controllers manually call <code>jwt.verify()</code> — functionally secure today

Risk	Inconsistent architecture: a future code change inside any handler could silently drop the auth check. All other protected routes use middleware uniformly.
-------------	---

Fix: Add `requireAuth` to all four routes in `authRoutes.js` and replace manual `getUserIdFromRequest` calls with `req.userId` set by the middleware.

Launch blocker: NO

SF-6 Password change does not invalidate existing sessions

Severity: MEDIUM

Location	PATCH <code>/api/auth/password</code> — <code>changeCurrentUserPassword</code> controller
Behavior	After a successful password change, all previously issued JWTs remain valid for up to 24 hours
Risk	If a user's password is compromised and they change it, the attacker's session token keeps working until it expires

Fix: Store a `password_changed_at` timestamp on the user. In `requireAuth`, verify the token's `iat` is after that timestamp and reject it if not.

Launch blocker: NO

SF-7 Password change allows trivially weak new passwords

Severity: MEDIUM

Location	PATCH <code>/api/auth/password</code> — <code>changeCurrentUserPassword</code> controller
Issue	No <code>PASSWORD_REGEX</code> check applied to <code>newPassword</code> — a user can change their password to '1'
Registration does validate	Yes — the gap exists only in the change-password flow

Fix: Apply the same `PASSWORD_REGEX` used in `authService.js` to the change endpoint.

Launch blocker: NO

SF-8 Booking IDOR correctly blocked

Severity: PASS

Test	Alice (authenticated) attempted PATCH <code>/api/bookings/16/cancel</code> (Bob's booking)
Result	403 Not authorized — ownership check enforced in <code>bookingModel.js</code>

SF-9 Conversation IDOR correctly blocked

Severity: PASS

Test	Carol (authenticated) attempted GET <code>/api/conversations/1/messages</code> (unrelated conversation)
Result	403 Access denied — participant check enforced in <code>messageController.js</code>

Bug Report

B-01 — CA\$ currency symbol displayed instead of PHP peso in provider services widget

Severity: HIGH

Confirmed live	Log in as Carol, switch to Provider Mode, view My Services — shows CA\$90, CA\$38/hr, CA\$35
Root cause	const sym = "CA\$" is hardcoded in ProviderServicesWidget.jsx line 297
Expected	All prices should show the PHP peso symbol (sign)
Fix	Change const sym = "CA\$" to const sym = "\u20B1" (PHP peso sign)
Priority	Must fix before launch

B-02 — Availability toggle makes zero API calls and does not persist

Severity: HIGH

Confirmed live	Clicked toggle in Provider Mode — network log shows no call to PUT /api/provider/profile. Refresh resets toggle.
Root cause	ProviderModeHeader.jsx only updates local React state on click; no API call is wired up
Expected	Toggle should persist the provider's availability status to the database
Fix	Wire toggle onClick to call PUT /api/provider/profile with the updated isProviderActive value
Priority	Must fix before launch

B-03 — Provider dashboard bio is hardcoded for all users

Severity: HIGH

Confirmed live	All providers see 'Manage your services and bookings' regardless of their actual profile bio
Root cause	ProviderDashboard.jsx constructs the profile from localStorage and hardcodes the bio string; no call to GET /api/provider/profile
Fix	Add a useEffect that calls GET /api/provider/profile on mount and uses the real displayName and bio
Priority	Must fix before launch

B-04 — Admin panel has no Reject button for pending users or services

Severity: HIGH

Confirmed live	Admin panel shows only an Approve button. No mechanism to formally deny a registration or service submission.
-----------------------	---

Impact	Admin cannot reject bad-actor registrations or inappropriate service listings through the UI
Fix	Add PATCH <code>/api/admin/users/:id/reject</code> and <code>/services/:id/reject</code> endpoints with corresponding UI buttons
Priority	Must fix before launch

B-05 — My Bookings link missing from dashboard navigation bar

Severity: MEDIUM

Confirmed live	DashboardNavbar contains: Home, Browse Services, Messages, Switch to Provider Mode, Profile, Logout — no My Bookings
Impact	Users cannot navigate to their bookings directly from the nav; must use dashboard widget or guess the URL
Fix	Add a My Bookings nav link pointing to <code>/my-bookings</code> in DashboardNavbar
Priority	Must fix before launch

B-06 — Admin panel renders the client DashboardNavbar showing 'Switch to Provider Mode'

Severity: MEDIUM

Confirmed live	Logged in as admin — nav shows 'Switch to Provider Mode', which is meaningless for admin
Root cause	AdminPage.jsx imports and renders DashboardNavbar identical to the client dashboard
Fix	Create a dedicated AdminNavbar or conditionally hide the provider-mode option based on role
Priority	Should fix soon

B-07 — Profile page Back button always navigates to `/client-dashboard` regardless of origin

Severity: MEDIUM

Confirmed live	Navigated to <code>/profile</code> from provider mode, clicked Back — went to <code>/client-dashboard</code>
Root cause	<code>navigate('/client-dashboard')</code> is hardcoded in ProfilePage.jsx line 328
Fix	Replace with <code>navigate(-1)</code> to return to the actual previous page
Priority	Should fix soon

B-08 — No notification sent to user when admin approves their registration

Severity: MEDIUM

Location	<code>adminController.js approveUser()</code> — no <code>createNotification</code> call for the approved user
-----------------	---

Contrast	Service approval correctly sends a notification to the provider; user approval does not
Impact	Approved users have no in-app signal that they can now log in; they must check by trying
Fix	Add <code>createNotification({ userId: targetId, type: 'account_approved', ... })</code> inside <code>approveUser</code> after <code>approveUserById</code>
Priority	Should fix soon

B-09 — success messages use `window.alert()` — jarring and unstyled

Severity: MEDIUM

Location	ProfilePage.jsx — profile save (line 246) and password change (line 248)
Observed	Browser native alert dialog appears on profile save and password change
Impact	Blocks the page thread; cannot be styled; inconsistent with the toast pattern used everywhere else in the app
Fix	Replace <code>window.alert()</code> calls with inline toast messages, matching the pattern in <code>MyBookingsPage.jsx</code>
Priority	Should fix soon

B-10 — Seed data contains 4 identical duplicate pending booking requests

Severity: MEDIUM

Confirmed live	Carol's provider dashboard shows 4 identical 'House Cleaning' requests from Alice — same date, time, message, price
Alice's view	My Bookings shows 8 active bookings from only 2 unique services
Root cause	Seed script created duplicate booking rows; no server-side duplicate guard exists
Fix	Clean seed data. Add a server-side check: reject booking if client already has a pending or accepted booking for the same service
Priority	Should fix soon

B-11 — Contact provider button remains enabled when provider is unavailable

Severity: LOW

Location	ServiceDetailPage.jsx line 162 — Contact button has no disabled guard
Contrast	Book Now button at line 153 is correctly disabled when <code>!service.isProviderActive</code>
Impact	Users can try to contact a provider whose services are unavailable, leading to a confusing empty interaction
Fix	Add <code>disabled={!service.isProviderActive}</code> to the Contact button, or display an 'Unavailable' note instead
Priority	Nice to fix later

B-12 — Profile page role badge is hardcoded as 'User' for all roles

Severity: LOW

Confirmed live	Both Alice (client) and Admin account display 'USER' badge on the profile page
Root cause	<code>User</code> is a static string in ProfilePage.jsx line 408
Fix	Conditionally render the badge label from profileUser.role
Priority	Nice to fix later

B-13 — Admin message logs have no pagination — returns all records

Severity: LOW

Location	GET /api/admin/message-logs — adminController.js returns all rows with no LIMIT
Risk	With active usage the response will grow unbounded, causing slow page loads and large memory use
Fix	Add LIMIT/OFFSET pagination to the query and a page control to the admin UI
Priority	Nice to fix later

B-14 — Live test garbage service visible in Browse Services for all users

Severity: LOW

Confirmed live	Service titled 'dirty house clean' with description 'pisdjfiosdjfi' by 'Ridge Liwanag' is live in the public browse listing
How it got there	It was submitted and approved through the admin approval flow
Fix	Delete the record from the database. Consider adding content guidelines to the approval checklist.
Priority	Fix before demo

Confirmed Working — Verified Live

Flow / Feature	Live Result
Landing page	All sections render, images load, no console errors
Contact form	201 Created, success banner shown, form resets
Registration — empty form	All 7 field-level error messages display correctly
Registration success	201 Created, redirects to login after 2.5s
Pending account login	Correct 'awaiting approval' message shown
Client login + dashboard	Correct redirect, welcome name displays
Services search filter	Filters results in real time, empty state shown
Book Now modal	Opens with correct service data, submits 201, closes
Booking cancel (confirm dialog)	Confirm dialog shows, PATCH 200, toast fires
My Bookings + status tabs	All bookings load, tabs filter correctly
Service detail page	Title, description, pricing, provider bio, reviews correct
Service 404 handling	'Service not found' message + back link
Provider mode access	Accessible to any authenticated user as designed
Provider booking request list	Loads real pending requests with client/price/message
Provider My Services list	Loads from API, correct approval status badges
Notifications bell	Opens dropdown, shows real notifications, mark read works
Messages empty state	'No conversations yet' shown correctly
Admin login redirect	Admin role routes correctly to /admin
Non-admin blocked from /admin	Redirected to /client-dashboard
Admin approve user	PATCH 200, success message, row removed from queue
Admin message logs	Full conversation log displayed
Logout session clearing	localStorage wiped, protected routes redirect to /login
Booking IDOR prevention	403 'Not authorized' — ownership enforced
Conversation IDOR prevention	403 'Access denied' — participant check enforced
Admin routes — no token	401 'Missing authorization token'
Admin routes — wrong role	403 'Admin access required'
JavaScript errors	ZERO errors across all pages and flows

Mobile / Responsive Results (375 x 812)

Page	Status	Notes
Landing page	PASS	Fits correctly, all sections visible

Login / Register	PASS	Layout fits, inputs accessible
Services page	PASS	No overflow, hamburger nav collapses correctly
Messages page	WARN	Panels stack vertically — usable but no toggle between thread list and active conversation
Provider Dashboard	FAIL	Body scrolls to 469px on 375px screen — .provider-column-left and widget rows overflow
Admin page	FAIL	Body scrolls to 903px — tables are 879px wide with no horizontal scroll wrapper

Launch Readiness Verdict

DO NOT SHIP — fix first:

- SF-1: Provider API authentication gap — unauthenticated attacker read/created/deleted/edited provider data live
- SF-2: JWT secret hardcoded fallback — trivially forgeable tokens if JWT_SECRET not set in production
- SF-3: No rate limiting on login, registration, booking, or contact form
- SF-4: /forgot-password blank page — dead link on the login screen
- B-04: No Reject button in admin panel — bad actors cannot be formally denied

Fix before client demo:

- B-01: CA\$ currency symbol instead of PHP peso in provider services widget (immediately visible)
- B-02: Availability toggle makes no API call — prominent feature that does nothing
- B-03: Provider dashboard bio hardcoded for all providers
- B-14: Delete 'dirty house clean' / 'pisdjfijsdjfi' test record from the database
- B-10: Provider dashboard mobile overflow (unusable at 375px)

Fix before public launch:

- SF-5: Add requireAuth middleware to profile/password routes for consistency
- SF-6: Password change should invalidate existing JWT sessions
- SF-7: Enforce password strength on the change-password endpoint
- B-05: My Bookings link missing from dashboard navbar
- B-06: Admin navbar shows 'Switch to Provider Mode' — wrong for admin role
- B-07: Profile Back button hardcoded to /client-dashboard
- B-08: No notification to user when their registration is approved
- B-09: Replace window.alert() success messages with inline toasts
- B-10: Add server-side duplicate booking prevention
- B-11: Contact button not disabled when provider is unavailable
- B-12: Profile role badge always shows 'User' regardless of actual role
- B-13: Admin message logs need pagination
- Admin page responsive tables (903px overflow on mobile)